



TOBB ETÜ
Ekonomi ve Teknoloji Üniversitesi

TOBB EKONOMİ VE TEKNOLOJİ ÜNİVERSİTESİ
Bilgisayar / Yapay Zekâ Mühendisliği
BİL 495 — YAP 495

High-Level Design Report

Yüksek Seviye Tasarım Raporu

Analiz modelinden sistem tasarım modeline geçiş — mimari, dağıtım, güvenlik

Proje Adı	Afet Durumlarında Mesh Tabanlı Acil Haberleşme Ağı
Takım Üyeleri	Ahmet Taha Özcan (231104085) · Mehmet Fatih Akay (231101026) · Umut Baran Boztaş (231101064) · Kaan Behzetoğlu (231101066) · Mert Dönmez (231101045)
Danışman	Dr. Shadi Bikas
Akademik Dönem	2025–2026 Yaz Dönemi
Teslim Tarihi	6.08.2026

İçindekiler

İçindekiler.....	2
1. Introduction	4
1.1 Purpose of the system	4
Dokümanın kapsamı ve hedef okuyucu kitlesi.....	4
1.2 Design goals	4
1.3 Definitions / Acronyms / Abbreviations.....	5
2. Current software architecture (if any)	6
3. Proposed software architecture	7
3.1 Overview	7
Mimari stil tercihi ve değerlendirilen alternatifler.....	7
3.2 Subsystem decomposition	8
Örnek akış: SOS mesajı gönderimi ve aktarımı (UC1)	9
3.3 Hardware / software mapping.....	10
Fiziksel katman seçimi: BLE ve Wi-Fi Direct'in rol ayrımı	10
3.4 Persistent data management.....	11
Veritabanı seçimi ve gerekçesi.....	11
Kavramsal şema	11
İndeksleme ve erişim örüntüleri	12
Yedekleme (backup) stratejisi.....	12
3.5 Access control and security.....	12
Kimlik doğrulama ve yetkilendirme (AuthN/AuthZ)	12
Şifreleme ve paket yapısı	12
Anahtar değişimi (ilk karşılaşma) adımları	13
Tehdit modeli ve önlemler	14
STRIDE tabanlı tehdit sınıflandırması.....	14
KVKK/GDPR uyumu	14
3.6 Global software control	15
Senkron / asenkron model.....	15
Hata kurtarma stratejisi	15
3.7 Boundary conditions	15
Cold start (soğuk başlangıç)	15
Kapatma (shutdown).....	16

Hata durumları (edge cases)	16
3.8 Traceability to requirements	16
4. Subsystem services	17
Application (UI) Subsystem — Servisler	17
Security Subsystem — Servisler	18
Routing Subsystem — Servisler	18
Connectivity Subsystem — Servisler	19
Local Message Store — Servisler	19
5. Glossary	20
6. References	20

1. Introduction

1.1 Purpose of the system

Bu doküman, “Afet Durumlarında Mesh Tabanlı Acil Haberleşme Ağı” projesinin analiz modelinden (ne yapılacağı) sistem tasarım modeline (hangi mimari ile yapılacağı) geçişini belgelemektedir. Analiz Raporu ve Gereksinimler Listesi'nde tanımlanan fonksiyonel ve fonksiyonel olmayan gereksinimlerin somut bir yazılım mimarisine, alt sistem sorumluluklarına, veri yönetimi stratejisine ve güvenlik mekanizmalarına nasıl haritalandığı bu raporun kapsamındadır. Rapor, henüz kod seviyesine inmeden; bileşen ayrıştırması, donanım/yazılım dağıtımı, kalıcı veri yönetimi, erişim kontrolü ve global yazılım kontrol stratejisini ortaya koyar.

Sistemin amacı, GSM şebekesinin, Wi-Fi altyapısının ve internet bağlantısının bir deprem veya benzeri doğal afet sonrasında kısmen ya da tamamen çöktüğü senaryolarda, kullanıcıların ellerindeki standart Android akıllı telefonları herhangi bir ek donanım veya merkezi sunucu olmaksızın bir araya getirerek kendiliğinden (ad-hoc) bir mesh iletişim ağı kurmasını sağlamaktır. Bu ağ üzerinden afetzedeler SOS/yardım mesajlarını konum bilgisiyle birlikte, aradaki cihazlar üzerinden çok sıçramalı (multi-hop) biçimde arama-kurtarma ekiplerine veya birbirlerine ulaştırabilir.

Dokümanın kapsamı ve hedef okuyucu kitlesi

Bu rapor, Analiz Raporu'nda tanımlanan davranışsal modelin (use case'ler, sınıf modeli, dinamik modeller) sistem tasarım moduna geçişini belgeler; yani “ne” sorusundan “hangi mimari ile” sorusuna geçişi temsil eder. Doküman; proje danışmanı Dr. Shadi Bikas, ekip içindeki her alt sistemden sorumlu geliştirici ve ileride projeye dahil olabilecek yeni katkıcılar için ortak bir mimari referans olarak hazırlanmıştır. Kod seviyesinde sınıf tanımları veya API imzaları bu raporun kapsamı dışındadır; bunlar Detaylı Tasarım (Low-Level Design) aşamasında ayrı bir dokümanda ele alınacaktır. Bu raporda yer alan mimari kararlar, Proje Önerisi'ndeki “Mimari Taslağı” bölümünde ortaya konan ilk fikrin; Gereksinimler Listesi'ndeki FR/NFR maddelerinin ve PKE-Plan'da taahhüt edilen standartlara uyumun (IEEE 802.15.1, RFC 3561, RFC 5280, RFC 7748, KVKK/GDPR) somutlaştırılmış halidir.

1.2 Design goals

Tasarım kararlarını yönlendiren temel hedefler ve çatışan hedefler arasında yapılan tercihlerin gerekçeleri aşağıda sıralanmıştır:

- **Altyapısızlık (Infrastructure Independence):** Sistem hiçbir merkezi sunucuya, baz istasyonuna veya ek donanıma (LoRa/Meshtastic cihazı gibi) bağımlı olmamalıdır. Bu, tek nokta arızasını (single point of failure) ortadan kaldırmak için projenin var oluş nedenidir.
- **Güvenilirlik > Ham Hız (Reliability over Raw Throughput):** Çatışan hedef: yüksek veri hızı ile düşük enerji/bant genişliği tüketimi arasında sistem, düşük hız ve yalnızca metin/koordinat taşıyan sınırlı bir veri modeli lehine tercih yapar (bkz. Pseudo Requirements — ses/görüntü aktarımı kapsam dışı); çünkü afet senaryosunda kritik olan mesajın ulaşması, zenginliği değildir.

- **Enerji Verimliliği (Battery Efficiency):** Cihazlar afet sonrası saatlerce/günlerce şarj imkânı bulamayabilir; bu nedenle sürekli tarama yerine periyodik (20 saniyede bir 5 saniyelik) BLE keşif döngüsü tercih edilmiştir (NFR3). Çatışan hedef: daha sık tarama, komşu keşfini hızlandırır ama pil tüketimini artırır — proje pil ömrünü önceliklendirir.
- **Uçtan Uca Gizlilik (End-to-End Confidentiality):** Aracı (relay) düğümler mesaj içeriğini asla okuyamazlar; yalnızca yönlendirme için gerekli başlık bilgisine erişebilirler. Bu hedef, Bridgefy'de (USENIX 2022) raporlanan zafiyetlerin tekrarlanmaması için sertleştirilmiştir.
- **Önceliklendirilmiş Teslimat (Priority-Aware Delivery):** Ağ tıkanıldığında SOS mesajları sıradan bilgilendirme mesajlarından önce iletilmelidir. Çatışan hedef: adil (FIFO) sıralama ile hayat kurtarıcı önceliklendirme arasında sistem açıkça önceliklendirmeyi seçer.
- **Sahada Sadelik ve Erişilebilirlik (Field Simplicity):** Kullanıcı arayüzü, panik anında tek dokunuşla SOS gönderimini desteklemeli (hazır şablonlar) ve minimum Android 8.0 (API 26) desteğiyle eski cihazların da ağa katılımına izin vermelidir.
- **Yatay Ölçeklenebilirlik (Scalability of the Mesh):** Mimari, düğüm sayısı arttıkça (10'dan 50+'a) merkezi bir darboğaz oluşturmadan çalışabilmelidir; bu nedenle her düğüm eşdeğer sorumluluğa (istemci + aktarıcı) sahiptir, hiyerarşik bir sunucu/istemci ayrımı yoktur.
- **Açık Kaynak ve Denetlenebilirlik (Auditability):** Bridgefy'nin aksine, kriptografik katman açık kaynak ve denetlenmiş kütüphanelere (libsodium) dayanır; “kendi şifreleme algoritmanı yazma” ilkesine uyulur, böylece güvenlik iddiaları bağımsızca doğrulanabilir.
- **Zarif Bozulma (Graceful Degradation):** Ağ parçalandığında (partition) veya hiç komşu bulunamadığında sistem çökmemeli, kullanıcıya durumu şeffaf biçimde bildirmeli ve mesajı kaybetmeden sakla-ilet durumuna geçmelidir. Çatışan hedef: kullanıcıya “her zaman çalışıyor” hissi vermek ile dürüst durum bildirimi arasında sistem ikincisini seçer — sahte güven duygusu can güvenliği açısından daha risklidir.

1.3 Definitions / Acronyms / Abbreviations

Terim	Tanım
AODV	Ad hoc On-Demand Distance Vector — talep üzerine yol bulan reaktif mesh yönlendirme protokolü (RFC 3561); projenin sıradan mesaj yönlendirme mantığına ilham kaynağıdır.
BLE	Bluetooth Low Energy — düşük enerjili kısa menzilli kablosuz iletişim standardı (IEEE 802.15.1); cihazlar arası fiziksel bağlantı katmanını sağlar.
TTL	Time-To-Live — bir paketin ağda en fazla kaç kez aktarılabileceğini belirten sıçrama sayacı; sonsuz döngüleri önler.
UUID	Universally Unique Identifier — her mesaja/cihaza atanan benzersiz kimlik; mesaj tekilliştirilmede (deduplication) kullanılır.
E2EE	End-to-End Encryption — uçtan uca şifreleme; yalnızca gönderen ve nihai alıcının mesaj içeriğini okuyabildiği şifreleme modeli.

Terim	Tanım
HMAC	Hash-based Message Authentication Code — paket başlığının bütünlüğünü ve kimlik doğrulamasını sağlayan imza mekanizması.
PKI / X.509	Public Key Infrastructure — açık anahtar altyapısı ve sertifika formatı (RFC 5280); bu projede merkezi bir Sertifika Otoritesi (CA) olmadığından hafifletilmiş (self-signed / TOFU) biçimde uygulanır.
X25519	RFC 7748'de tanımlı, en az 256-bit güvenlik seviyesi sunan eliptik eğri tabanlı anahtar değişim algoritması.
Store-and-Forward	Sakla-ilet — alıcı menzilde değilken mesajın taşıyıcı cihazda saklanıp uygun bir düğüm bulunduğunda iletilmesi tekniği.
Deduplication	Tekilleştirme — daha önce görülmüş bir mesajın UUID'sine bakılarak tekrar işlenmesinin engellenmesi.
Rate Limiting	Bir düğümün saniyede kabul edebileceği paket sayısının sınırlandırılması; broadcast storm / flood saldırılarına karşı önlem.
KVKK / GDPR	Kişisel Verilerin Korunması Kanunu ve AB Genel Veri Koruma Tüzüğü; kişisel veri (konum, cihaz kimliği, mesaj içeriği) işleme yükümlülükleri.
Cold Start	Uygulamanın ilk kurulumdan sonra veya cihaz yeniden başlatıldıktan sonraki ilk çalıştırılma durumu.

2. Current software architecture (if any)

Bu proje sıfırdan geliştirilen yeni bir sistem olduğundan, değiştirilecek veya genişletilecek mevcut bir yazılım mimarisi bulunmamaktadır. Bununla birlikte, Analiz Raporu'nda incelenen mevcut çözümlerin mimari zayıflıkları, tasarım kararlarını doğrudan şekillendirmiştir ve bu bölümde referans olarak özetlenmektedir.

- **Standart hücresel/Wi-Fi iletişim:** “Yıldız Topolojisi” üzerine kuruludur; tüm cihazlar merkezi bir baz istasyonuna veya yönlendiriciye bağımlıdır. Merkezi düğüm hasar gördüğünde, elektriği kesildiğinde veya kapasitesi dolduğunda (afet sonrası yoğunluk) tüm ağ çöker — klasik tek nokta arızası (single point of failure) örneğidir.
- **Harici donanım tabanlı çözümler (telsiz, LoRa/Meshtastic):** İşlevseldir ancak kullanıcıların önceden satın alması gereken ek donanım gerektirir; afet anında halkın elinde bulunmama olasılığı yüksektir.
- **Bridgefy gibi mevcut yazılım tabanlı mesh uygulamaları:** Ek donanım gerektirmez, ancak kapalı kaynak kod yapısı, ticari lisanslama riskleri ve USENIX Security 2022'de raporlanan somut kriptografik zafiyetler (libsignal'in yanlış uygulanması, tekrar oynatma ve kimlik sahteciliği açıkları) barındırır.

Bu üç kategori de bu projenin konumlandığı boşluğu tanımlar: donanım gerektirmeyen, açık kaynaklı ve denetlenmiş kriptografiye dayanan, merkezi altyapıdan bağımsız bir yazılım çözümü. Aşağıdaki tablo, mevcut alternatifleri önerilen sistemle karşılaştırmaktadır.

Çözüm	Ek Donanım	Zayıf Yönler	Güçlü Yönler	Bu Projeye Temel mi?
Hücrese/Wi-Fi (Yıldız Topoloji)	Yok	Merkezi baz istasyonu/router hasar görürse tüm ağ çöker (SPOF)	Yaygın, ek kurulum yok	—
Telsiz (Walkie-talkie)	Evet (telsiz cihazı)	Ses odaklı, dijital veri/konum aktaramaz, lisans gerektirebilir	Kanıtlanmış, düşük gecikme	—
LoRa / Meshtastic	Evet (harici LoRa modülü)	Kullanıcının önceden satın alıp taşıması gerekir; afet anında elde olmayabilir	Uzun menzil (km)	—
Bridgefy (yazılım, kapalı kaynak)	Yok	USENIX 2022'de raporlanan kriptografik zafiyetler, kapalı kaynak, ticari lisans riski	Ek donanım gerektirmez	Kısmen (mimari ilham, olumsuz örnek)
Önerilen Sistem	Yok	Menzil BLE ile sınırlı (~20 m/hop), yalnızca metin/koordinat	Açık kaynak, E2EE, SOS önceliklendirme, ek donanım yok	Evet

3. Proposed software architecture

3.1 Overview

Önerilen mimari, merkezi bir sunucuya bağımlı olmayan, katmanlı ve tamamen merkeziyetsiz (decentralized peer-to-peer) bir yapıya dayanır. Ağdaki her Android cihaz eşdeğer bir düğüm olarak çalışır ve aynı anda hem mesaj üreten/tüketen bir istemci hem de başkalarının mesajını taşıyan bir aktarıcı (relay) görevi görür. Sistem “Store-and-Forward” (Sakla-İlet) ve çok sıçramalı yönlendirme (multi-hop routing) ilkeleri üzerine kuruludur; acil (SOS) mesajlar için kontrollü taşkın (controlled flooding, TTL sınırlı) ve sıradan mesajlar için AODV ilkelerinden esinlenen talep-üzerine yönlendirme birlikte kullanılır.

Her düğüm, sorumlulukları birbirinden net biçimde ayrılmış beş alt sistemden oluşur: Application (UI), Security, Routing, Connectivity ve Local Message Store. Bu ayırım hem ekip içi iş bölümünü (her üye bir alt sistemden sorumlu) hem de her bileşenin bağımsız test edilebilmesini kolaylaştırır.

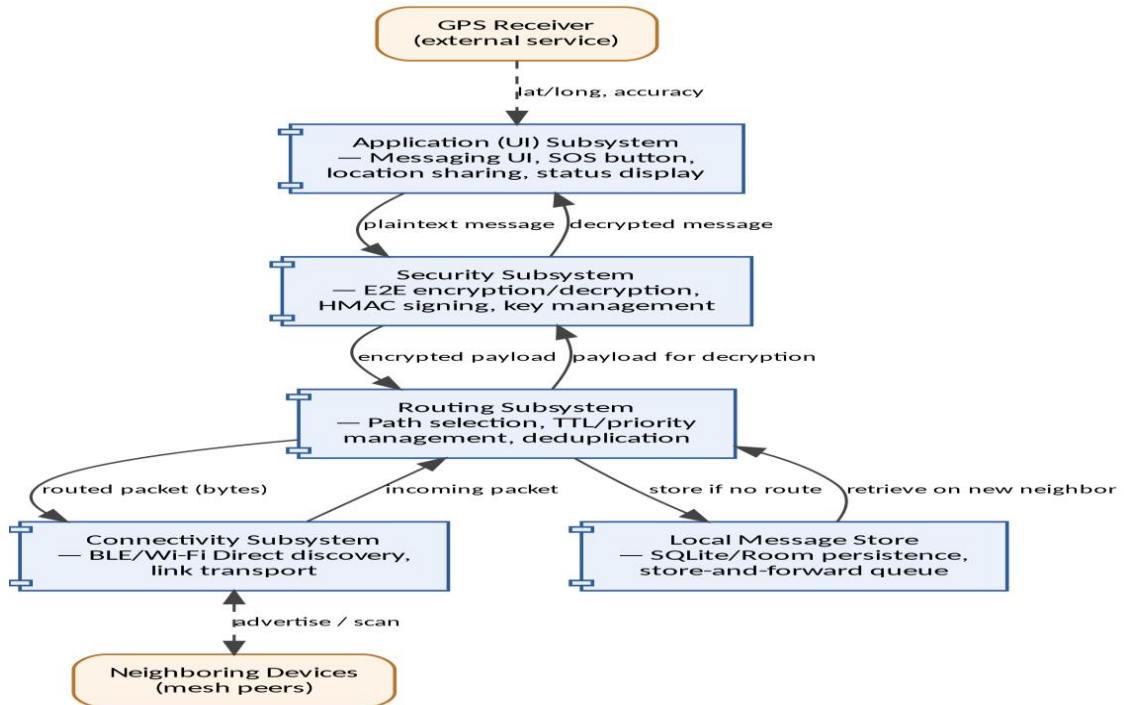
Mimari stil tercihi ve değerlendirilen alternatifler

Katmanlı P2P mesh mimarisine karar verilmeden önce, ekip ve danışman geri bildirimleri doğrultusunda üç alternatif mimari stil değerlendirilmiştir. Aşağıdaki tablo bu değerlendirmeyi ve tercih gerekçesini özetler.

Mimari Stil	Artıları	Eksileri	Karar
Merkezi İstemci-Sunucu	Basit geliştirme, tutarlı durum yönetimi	İnternet/sunucu bağımlılığı; afet senaryosunda temel varsayımla ("altyapı çökmüş") doğrudan çelişir	Reddedildi
Hibrit (Gateway düğümlü mesh)	Bazı düğümler internet/gateway'e erişebiliyorsa dış dünyaya köprü kurulabilir	Gateway düğümü tek nokta darboğazı yaratır; afetin ilk saatlerinde hiçbir düğümün internete erişemeyeceği varsayılmalı	ileri hedef olarak not edildi, mevcut kapsamda yok
Saf Taşkın (Pure Flooding)	Uygulaması en basit yönlendirme stratejisi	Ağ trafiğini gereksiz yere şişirir, pil tüketimini artırır, önceliklendirmeye izin vermez	Reddedildi (yalnızca SOS için sınırlı biçimde kullanılıyor)
Katmanlı Merkeziyetsiz P2P Mesh (Seçilen)	Tek nokta arızası yok, her düğüm eşit, önceliklendirme ve sakla-ilet destekler	Rota bulma garantisi yok (ağ parçalanmışsa mesaj ulaşmayabilir); bu NFR4 ile ölçülüp kabul edilmiş bir sınırlılıktır	Seçildi

3.2 Subsystem decomposition

Aşağıdaki UML bileşen diyagramı, alt sistemler arasındaki veri akışını ve dış servislerle (GPS, komşu cihazlar) olan etkileşimi göstermektedir.



Şekil 1 — Sistem Bileşen (Component) Diyagramı

Alt Sistem	Sorumluluk
Application (UI) Subsystem	Kullanıcı arayüzü: mesaj yazma, SOS gönderme, hazır SOS şablonları, konum paylaşımı, mesaj durum göstergeleri (Gönderiliyor / Mesh Ağına İletildi / Nihai Alıcıya Ulaştı) ve ağ durumu görüntüleme (UC1, UC3, UC5, UC6, UC7).
Security Subsystem	Giden mesajların X25519 tabanlı uçtan uca şifrelenmesi, gelen mesajların çözülmesi, paket başlığının HMAC ile imzalanması/doğrulanması, cihaz kimliği (anahtar çifti) yönetimi (FR6).
Routing Subsystem	Sistemin çekirdek mantığı: rota seçimi, SOS önceliklendirme (FR2), TTL yönetimi, UUID tabanlı tekilleştirme/deduplication (FR5), sakla-ilet kararının tetiklenmesi (FR4).
Connectivity Subsystem	BLE advertising/scanning ile komşu keşfi (FR1), Wi-Fi Direct üzerinden yüksek hacimli aktarım, düşük seviye bayt dizisi iletimi/alımı.
Local Message Store	İletilemeyen mesajların ve mesaj geçmişinin cihaz üzerinde kalıcı olarak saklanması (FR8); SQLite/Room üzerinden erişim.

Modüller birbirine yalnızca net tanımlı arayüzler üzerinden bağlıdır; her modül kendi görevinden sorumludur ve diğerinin iç işleyişini bilmek zorunda değildir. Bir mesaj gönderildiğinde veri sırasıyla UI → Security (şifreleme) → Routing (rota/öncelik) → Connectivity (fiziksel iletim) katmanlarından geçer; alıcı tarafta bu akış ters yönde işler. Alıcı menzilde değilse Routing Subsystem mesajı Local Message Store'a yazar ve uygun bir komşu bulununca yeniden dener.

Örnek akış: SOS mesajı gönderimi ve aktarımı (UC1)

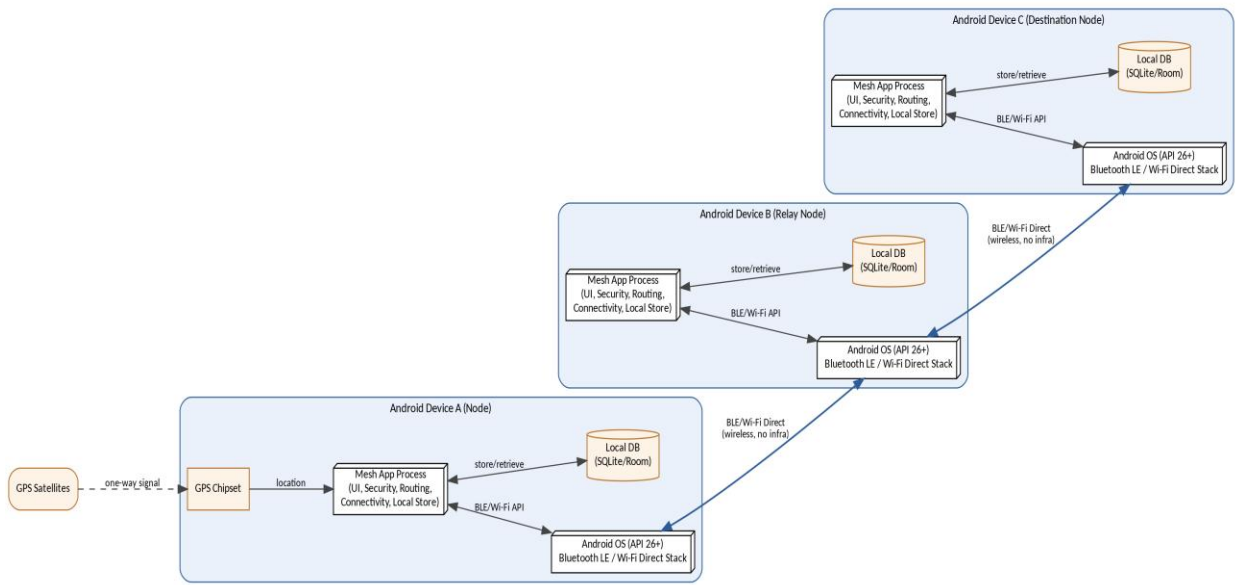
Aşağıdaki adımlar, bir kullanıcının SOS mesajı gönderdiği andan mesajın bir aracı düğüm üzerinden nihai alıcıya ulaşmasına kadar alt sistemler arasındaki etkileşim sırasını gösterir:

1. Kullanıcı, Application (UI) Subsystem üzerinden bir SOS şablonu seçer (ör. “Enkaz altındayım”); UI, cihaz GPS'inden anlık konumu okuyarak mesaja ilişirir (UC2 include).
2. UI, düz metin mesajı ve konumu Security Subsystem'e iletir; Security, hedefin (varsa) veya ağ genel yayınının açık anahtarıyla payload'ı X25519 ile şifreler ve HMAC imzalı bir header oluşturur.
3. Şifreli paket Routing Subsystem'e geçer; paket SOS önceliği taşıdığından öncelik kuyruğunun başına yerleştirilir ve TTL=10 gibi bir başlangıç değeriyle etiketlenir.
4. Routing, Connectivity Subsystem'den o an menzildeki komşu düğüm listesini sorgular. Menzilde komşu varsa paket bayt dizisi olarak Connectivity üzerinden BLE/Wi-Fi Direct ile iletilir.
5. Menzilde komşu yoksa Routing, paketi Local Message Store'a yazar (sakla-ilet) ve Connectivity'den “yeni komşu keşfedildi” bildirimini bekler.

6. Paketi alan aracı düğümde: Connectivity gelen baytları Routing'e iletir; Routing, UUID'yi kontrol ederek tekrar mı olduğuna bakar (deduplication), değilse TTL'i bir azaltır ve kendisi hedef değilse aynı akışı bir sonraki komşuya doğru tekrarlar (relay, UC4).
7. Paket nihai hedefine (veya arama-kurtarma ekibinin gateway cihazına) ulaştığında, o düğümde Security Subsystem payload'ı özel anahtarla çözer ve UI, mesajı konumuyla birlikte görüntüler (UC5, UC6); köken düğümdeki UI durumu “Nihai Alıcıya Ulaştı” olarak güncellenir (FR7).

3.3 Hardware / software mapping

Aşağıdaki UML dağıtım (deployment) diyagramı, yazılım bileşenlerinin fiziksel Android cihazlar üzerine ve cihazlar arası kablosuz iletişim kanallarına nasıl dağıtıldığını göstermektedir.



Şekil 2 — Dağıtım (Deployment) Diyagramı: Üç örnek düğüm üzerinden çok sıçramalı iletim

Her Android cihaz, Android OS'in yerleşik BLE/Wi-Fi Direct yığını üzerinde çalışan tek bir uygulama sürecini (mesh app process) barındırır; bu süreç beş alt sistemi de içerir ve harici bir sunucu düğümü yoktur — yani “sunucu” ile “istemci” arasında donanımsal bir ayrım bulunmaz. Cihazlar arası iletişim doğrudan BLE/Wi-Fi Direct üzerinden, herhangi bir ara altyapı (router, baz istasyonu, internet gateway) olmadan gerçekleşir. GPS çipi, uydudan tek yönlü sinyal aldığından hücresel şebeke veya internet olmadan da çalışmaya devam eder ve konum verisini uygulama sürecine iletir. Yerel veritabanı (SQLite/Room), her cihazın kendi dosya sisteminde, cihaza özel ve şifrelenmemiş meta veriler ile (payload şifreli olarak) saklanır — cihazlar arasında paylaşılan veya senkronize edilen merkezi bir veri deposu yoktur.

Fiziksel katman seçimi: BLE ve Wi-Fi Direct'in rol ayrımı

Connectivity Subsystem, iki farklı kablosuz teknolojiyi tamamlayıcı biçimde kullanır; hangisinin ne zaman devreye gireceği aşağıdaki tabloda özetlenmiştir.

Kriter	BLE (Bluetooth Low Energy)	Wi-Fi Direct
Tipik Menzil	~20 m (kapalı/açık alana göre değişir)	~50–100 m (açık alanda daha fazla)
Enerji Tüketimi	Çok düşük (NFR3 hedefiyle uyumlu, keşif için ideal)	Daha yüksek (yalnızca aktif veri transferinde kullanılır)
Kullanım Amacı	Komşu keşfi (advertising/scanning), küçük paketler (header, kısa mesajlar)	Büyük hacimli veri aktarımı gerektiğinde (çok sayıda kuyruklanmış mesaj)
Bağlantı Kurulum Süresi	Hızlı (düşük gecikme, NFR1 hedefi)	Görece daha yavaş (eşleştirme adımı gerekir)
Android API Seviyesi	API 26+ (BLE Advertise/Scan)	API 26+ (Wi-Fi Direct / Nearby Connections P2P_CLUSTER)

Pratikte Connectivity Subsystem varsayılan olarak BLE üzerinden düşük enerjili keşif ve küçük paket iletimini yürütür; Google Nearby Connections'ın P2P_CLUSTER modu gerektiğinde otomatik olarak Wi-Fi Direct'e geçerek daha yüksek bant genişliği sağlar. Bu ikili yaklaşım, NFR2 (bellek) ve NFR3 (batarya) sınırları içinde kalırken NFR1 (gecikme) ve NFR4 (teslimat oranı) hedeflerine ulaşmayı amaçlar.

3.4 Persistent data management

Veritabanı seçimi ve gerekçesi

Kalıcı veri yönetimi için Android Jetpack Room (SQLite üzerine ORM katmanı) tercih edilmiştir. Gerekçeler: (1) Sakla-ilet mimarisi, iletilmeyen mesajların cihaz üzerinde kalıcı olarak tutulmasını zorunlu kılar; Room, uygulama süreci kapansa veya cihaz kapansa dahi bu kalıcılığı disk üzerinde garanti eder (FR8). (2) Room, Android'in yerleşik SQLite motorunu sarmaladığından ek bir sunucu süreci veya ağ bağlantısı gerektirmez — tamamen çevrimdışı çalışma hedefiyle örtüşür. (3) Apache 2.0 lisansı, projenin açık kaynak lisans stratejisiyle uyumludur (bkz. Üçüncü Taraf Lisans Analizi). (4) Derleme zamanı SQL doğrulaması ve tip güvenliği, ekip içi geliştirme hatalarını azaltır.

Kavramsal şema

Tablo	Alanlar
Message	id (UUID, PK), content (encrypted BLOB), priority (SOS/NORMAL), ttl (Int), timestamp (DateTime), senderId (FK→Device), destinationId (FK→Device, nullable), status (Enum)
Location	messageId (FK→Message, 1:1), latitude (Double), longitude (Double), accuracy (Double)
Device	deviceId (UUID, PK), publicKey (String), lastSeenTimestamp (DateTime), batteryLevel (Int, opsiyonel/teşhis amaçlı)
RoutingEntry	messageId (FK→Message), nextHop (FK→Device), hopCount (Int), seenAt (DateTime) — deduplication ve TTL takibi için

İlişkiler: bir Device birden fazla Message üretebilir (1:N); bir Message en fazla bir Location'a sahiptir (1:1, yalnızca SOS mesajlarında dolu); bir Message, ağda ilerlerken birden fazla RoutingEntry üretebilir (1:N). Payload alanı (content) veritabanında her zaman şifreli biçimde tutulur; şifre çözme yalnızca bellekte, görüntüleme anında yapılır — bu, cihaz ele geçirilse dahi geçmiş mesajların anahtar olmadan okunamamasını sağlar.

İndeksleme ve erişim örüntüleri

Routing Subsystem'in en sık çalıştırdığı iki sorgu — “bu UUID daha önce görüldü mü?” (deduplication) ve “hangi mesajlar hâlâ bekliyor?” (sakla-ilet yeniden deneme) — performans açısından kritik olduğundan Message tablosunda id (UUID) alanı üzerinde birincil anahtar indeksi, status ve priority alanları üzerinde ise bileşik bir indeks tanımlanır. Bu sayede öncelik kuyruğu her komşu keşfinde tüm tabloyu taramak yerine yalnızca “status = PENDING” kayıtlarını, SOS önceliğini önce döndürecek şekilde sorgulayabilir. RoutingEntry tablosunda ise messageid üzerindeki indeks, bir mesajın ağdaki geçmişinin hızlıca sorgulanmasını sağlar.

Yedekleme (backup) stratejisi

Sistem tasarımı gereği merkezi/bulut tabanlı bir yedekleme mekanizması bilinçli olarak bulunmamaktadır: internet erişimi zaten yok sayıldığından böyle bir servis çalışma zamanında erişilemez olurdu ve KVKK/GDPR kapsamında hassas verilerin (konum, SOS içeriği) üçüncü bir sunucuya taşınması ek bir gizlilik riski oluştururdu. Bunun yerine dayanıklılık, verinin ağ genelinde doğal olarak çoğaltılmasından (aynı mesajın birden fazla aracı düğümde geçici olarak tutulması) ve Android'in kendi “Auto Backup” mekanizmasının bu hassas tabloyu kapsam dışı bırakacak şekilde yapılandırılmasından (allowBackup=false / özel dışlama kuralları) sağlanır.

3.5 Access control and security

Kimlik doğrulama ve yetkilendirme (AuthN/AuthZ)

Merkezi bir Sertifika Otoritesi (CA) veya internet erişimi bulunmadığından klasik PKI/X.509 hiyerarşisi (RFC 5280) doğrudan uygulanamaz. Bunun yerine sistem, her cihazın ilk kurulumda kendi X25519 anahtar çiftini yerel olarak ürettiği ve kimliğini bu açık anahtarla temsil ettiği hafifletilmiş, sertifika benzeri bir model kullanır: her cihaz kendi açık anahtarını RFC 5280'in alan yapısından (subject, geçerlilik süresi, imza) esinlenen sadeleştirilmiş bir öz-imzalı (self-signed) kimlik nesnesi olarak taşır. Yeni bir komşu ilk karşılaşıldığında “Trust-On-First-Use (TOFU)” ilkesiyle kabul edilir ve açık anahtarı yerel cihaz tablosuna (Device) kaydedilir; bu, merkezi doğrulama altyapısı olmayan bir ortamda pratik ve literatürde kabul görmüş bir yaklaşımdır.

Yetkilendirme, düğüm rolleri arasında bir hiyerarşi öngörmez: her düğüm hem gönderici hem aktarıcı olarak eşit haklara sahiptir. Ancak aktarıcı düğümler yalnızca paket başlığını (header) okuyabilir; payload'a erişim yalnızca hedef cihazın özel anahtarıyla mümkündür — bu, yetkilendirmenin veri erişim düzeyinde, kriptografik olarak zorlanmasıdır.

Şifreleme ve paket yapısı

Paket yapısı ikiye ayrılır: Header (TTL, UUID, gönderici/hedef ID) şifresiz ancak HMAC ile imzalıdır — aracı düğümlerin yönlendirme kararı verebilmesi için okunabilir olmalıdır, ancak değiştirilmesi imza doğrulamasıyla engellenir. Payload (gerçek mesaj içeriği ve GPS verisi) libsodium kütüphanesi kullanılarak X25519 (en az 256-bit, RFC 7748) ile uçtan uca şifrelenir; yalnızca hedefin özel anahtarıyla çözülebilir (NFR5, FR6). Anahtar türetme fonksiyonu (KDF) en az 10.000 iterasyonlu PBKDF2 standardına uyar. Aşağıdaki şekil, bir mesh paketinin alan yapısını göstermektedir.

Mesh Paketi (Packet)	
HEADER — şifresiz, HMAC ile imzalı	
UUID	benzersiz mesaj kimliği (deduplication)
TTL	sıçrama sınırı (hop limit)
Sender ID	gönderici cihaz kimliği
Destination ID	hedef cihaz kimliği (opsiyonel)
Priority	SOS / NORMAL etiketi
Timestamp	replay koruması için zaman damgası
HMAC	başlık bütünlük imzası
PAYLOAD — X25519 ile uçtan uca şifreli	
Content	mesaj metni (şifreli)
Location	lat / long / accuracy (şifreli, opsiyonel)

Şekil 3 — Mesh Paket Yapısı: Şifresiz/İmzalı Header ve Şifreli Payload

Anahtar değişimi (ilk karşılaşma) adımları

1. Cihaz A ve Cihaz B ilk kez BLE menziline girer; Connectivity Subsystem karşılıklı advertising paketlerini algılar.
2. Her iki cihaz da kendi açık X25519 anahtarını, hafifletilmiş self-signed kimlik nesnesi (sadeleştirilmiş X.509 alanları: subject=deviceId, geçerlilik, imza) biçiminde küçük bir handshake paketiyle karşı tarafa gönderir.
3. Security Subsystem, gelen açık anahtar TOFU ilkesiyle kabul eder ve Device tablosuna (deviceId, publicKey, lastSeenTimestamp) kaydeder; bu noktadan sonra bu cihaz çiftinin paylaşımlı gizli anahtar (shared secret) X25519 Diffie-Hellman ile yerel olarak türetilir.

4. Sonraki tüm mesajlaşmalarda bu paylaşımlı gizli anahtardan türetilen oturum anahtarı, payload şifrelemesinde kullanılır; anahtar tekrar ağ üzerinden taşınmaz.

Tehdit modeli ve önlemler

Tehdit	Önlem
Replay (Tekrar Oynatma)	Her pakette benzersiz UUID ve zaman damgası (timestamp); daha önce görülen kimlikler Routing Subsystem tarafından reddedilir.
Sahte Düğüm (Fake Node)	E2EE nedeniyle payload okunamaz; HMAC imzası nedeniyle header değiştirilemez veya sahte köken gösterilemez.
Broadcast Storm / Flood	TTL sınırı ve cihaz başına rate limiting (saniyede en fazla 5 paket kabulü) ile ağın tıkanması engellenir.
Cihaz ele geçirilmesi (fiziksel)	Yerel veritabanında payload her zaman şifreli tutulur; anahtarlar Android Keystore benzeri güvenli donanım destekli depoda saklanır.

STRIDE tabanlı tehdit sınıflandırması

Yukarıdaki senaryo-bazlı tehdit modeli, tamlığı doğrulamak amacıyla STRIDE çerçevesiyle de çapraz kontrol edilmiştir:

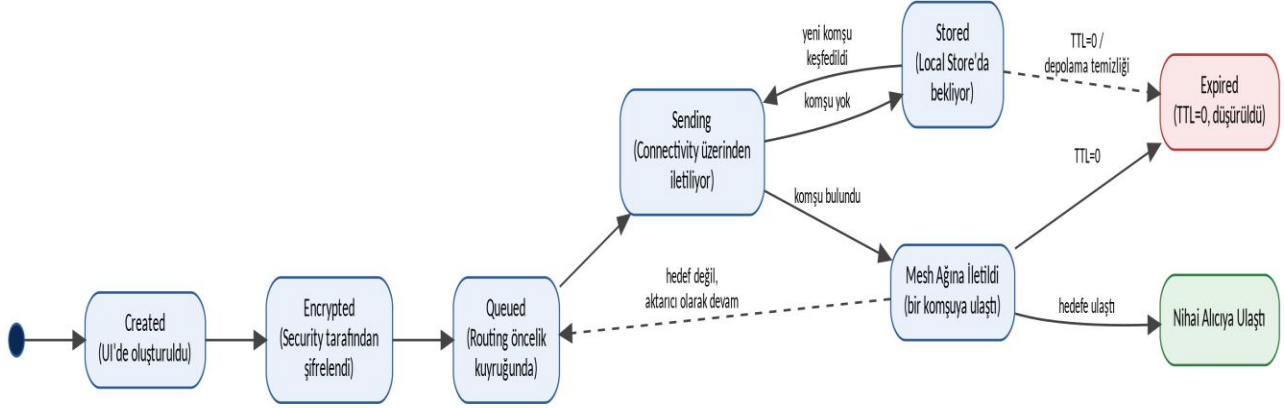
STRIDE Kategorisi	Mimari Önlem
Spoofing (Kimlik Sahteciliği)	TOFU + açık anahtar eşleştirmesi; her mesaj HMAC ile imzalı olduğundan sahte gönderici kimliği paket doğrulamasında elenir.
Tampering (Değiştirme)	Header HMAC imzası; payload zaten E2EE olduğundan aracı düğümler değişiklik yapamaz, yapsa da alıcıda bütünlük kontrolü başarısız olur.
Repudiation (İnkâr)	UUID + timestamp + imzalı header, bir mesajın kaynağının sonradan inkâr edilmesini zorlaştırır (yerel günlük ile birlikte).
Information Disclosure (Bilgi İfşası)	Payload E2EE; yalnızca header (TTL, UUID, öncelik) açık metindir ve kişisel veri içermez.
Denial of Service (Hizmet Reddi)	Rate limiting (saniyede 5 paket) ve TTL sınırı; broadcast storm senaryosuna karşı önlem.
Elevation of Privilege (Yetki Yükseltme)	Düğümler arasında ayrıcalık hiyerarşisi olmadığından yükseltilecek bir yetki yoktur; her düğüm zaten eşit haklara sahiptir.

KVKK/GDPR uyumu

Sistem; kullanıcı adı, cihaz kimliği, GPS konumu ve SOS mesaj içeriği gibi kişisel ve özel nitelikli verileri işlediğinden, veri minimizasyonu ilkesi ve uçtan uca şifreleme, KVKK m.12 ve GDPR Madde 32 veri güvenliği yükümlülükleriyle uyum gözetilerek uygulanır. Aracı düğümlerin veriye erişememesi, merkeziyetsiz sistemlerde “veri sorumlusu” kavramının nasıl uygulanabileceğine dair mimari düzeyde bir cevap sunar: hiçbir düğüm, kendi ürettiği veya kendisine yönelik olmayan içeriğin veri sorumlusu/işleyeni sayılamaz.

3.6 Global software control

Aşağıdaki durum (state) diyagramı, bir mesajın yaşam döngüsü boyunca geçtiği durumları ve bu geçişleri tetikleyen alt sistem etkileşimlerini gösterir; bu diyagram global kontrol akışının merkezi bir özetiştir.



Şekil 4 — Mesaj Yaşam Döngüsü Durum Diyagramı

Senkron / asenkron model

Sistem büyük ölçüde olay güdümlü (event-driven) ve asenkronudur. BLE tarama/keşif, bağlantı kurma ve veri alışverişi Android'in asenkron Bluetooth API geri çağrılarını (callback) üzerinden yürütülür; UI hiçbir zaman ağ işlemleri için bloklanmaz. Routing Subsystem, gelen paketleri bir kuyruk (öncelik kuyruğu: SOS > NORMAL) üzerinden asenkron olarak işler; Security Subsystem'in şifreleme/çözme işlemleri de arka plan iş parçacıklarında (coroutine/worker) gerçekleştirilir. Yalnızca yerel veritabanı yazma/okuma işlemleri (Local Message Store) atomik işlemler (transaction) içinde senkronize edilir, böylece eşzamanlı erişimde veri tutarlılığı korunur.

Hata kurtarma stratejisi

- **Bağlantı kopması:** Routing Subsystem, iletemeyen mesajı otomatik olarak Local Message Store'a yazar (sakla-ilet); yeni bir komşu keşfedildiğinde Connectivity Subsystem'den gelen bildirim üzerine yeniden deneme tetiklenir.
- **Kısmi/bozuk paket alımı:** HMAC doğrulaması başarısız olan paketler sessizce reddedilir (drop) ve işlenmez; bu, hem bütünlük hatalarını hem de kötü niyetli değişiklikleri aynı mekanizmayla ele alır.
- **Sonsuz döngü / rota bulunamaması:** TTL sıfıra ulaştığında paket düşürülür; gönderen tarafta durum "Mesh Ağına İletildi" aşamasında kalır ve kullanıcı yanlış bir güven hissine kapılmaması için bilgilendirilir (bkz. Analiz Raporu, Senaryo).
- **Uygulama çökmesi/yeniden başlatma:** Tüm bekleyen mesajlar ve yönlendirme durumu kalıcı depoda tutulduğundan (FR8), uygulama yeniden başlatıldığında kaldığı yerden devam eder; bellekte tutulan geçici durum (ör. aktif BLE bağlantı listesi) sıfırdan yeniden inşa edilir.

3.7 Boundary conditions

Cold start (soğuk başlangıç)

İlk kurulumda uygulama: (1) gerekli izinleri (Bluetooth, Konum, arka plan çalışma) kullanıcıdan ister; (2) Security Subsystem cihaz için yerel bir X25519 anahtar çifti üretir ve özel anahtarı güvenli donanım destekli depoda saklar; (3) Local Message Store boş bir veritabanı şeması ile başlatılır; (4) Connectivity Subsystem BLE advertising/scanning döngüsünü başlatır. İzinlerden herhangi biri reddedilirse sistem, hangi işlevlerin (ör. konum paylaşımı) devre dışı kalacağını kullanıcıya açıkça bildirir ve mesh keşfi olmadan çalışmaya devam etmez.

Kapatma (shutdown)

Kullanıcı uygulamayı kapattığında veya cihazın bataryası bittiğinde: bekleyen tüm mesajlar ve yönlendirme durumu zaten kalıcı depoda (Room) tutulduğundan ayrı bir “kapatma prosedürü” gerekmez — bu, tasarımın temel dayanıklılık ilkesidir. Aktif BLE bağlantıları Android OS tarafından güvenli biçimde sonlandırılır; herhangi bir veri kaybı yaşanmaz çünkü commit edilmemiş mesaj yoktur (her mesaj alınır alınmaz veya üretilir üretilmez veritabanına yazılır).

Hata durumları (edge cases)

- **Komşu bulunamaması:** UI, ağ durumu ekranında (UC7) “0 bağlı düğüm” bilgisini gösterir; mesajlar sakla-ilet kuyruğunda bekletilir.
- **GPS sinyali yok/zayıf (enkaz altı):** SOS mesajı konum bilgisi olmadan da gönderilebilir; konum alanı boş bırakılır ve kullanıcıya bu durum bildirilir.
- **Yerel depolama dolması:** En eski, zaten teslim edilmiş (status = delivered) kayıtlar öncelikli olarak temizlenir (LRU benzeri politika); bekleyen/teslim edilmemiş SOS mesajları asla otomatik silinmez.
- **Çakışan aynı UUID'li iki farklı mesaj (bozulma/saldırı şüphesi):** İlk görülen kabul edilir, sonrakiler reddedilir; olay teşhis amaçlı yerel günlüğe (log) düşülür.
- **Aynı anda birden fazla komşu ile bağlantı (çoklu erişim):** Connectivity Subsystem, Nearby Connections'ın P2P_CLUSTER (M-to-N) modunu kullanarak birden fazla eşzamanlı bağlantıyı destekler; Routing Subsystem her komşu için bağımsız bir gönderim denemesi yürütür.
- **Uygulama izinlerinin sonradan geri alınması:** Bluetooth veya konum izni çalışma zamanında kapatılırsa Connectivity/UI ilgili işlevi devre dışı bırakır ve kullanıcıyı yeniden izin vermeye yönlendirir; bekleyen mesajlar veri kaybı olmadan kalıcı depoda kalmaya devam eder.
- **Saat senkronizasyon farkı (cihazlar arası zaman damgası tutarsızlığı):** Replay koruması yalnızca timestamp'e değil, aynı zamanda görülen UUID kümesine dayandığından; cihazlar arası küçük saat kaymaları güvenlik kontrolünü tek başına geçersiz kılmaz.

3.8 Traceability to requirements

Aşağıdaki matris, Gereksinimler Listesi'ndeki her bir fonksiyonel/fonksiyonel olmayan gereksinimin bu raporda hangi alt sistem(ler) tarafından karşılandığını göstererek analiz modeli ile tasarım modeli arasındaki izlenebilirliği sağlar.

Gereksinim	Sorumlu Alt Sistem	İlgili Bölüm(ler)
FR1 — Otomatik Akran Keşfi	Connectivity Subsystem	3.2, 3.3
FR2 — SOS Önceliklendirme	Routing Subsystem	3.2, 3.6
FR3 — GPS Konum İliştirme	Application (UI) Subsystem (GPS ile birlikte)	3.2, 3.3
FR4 — Sakla-İlet Mekanizması	Routing Subsystem + Local Message Store	3.2, 3.4, 3.6
FR5 — Mükerrer Paket Engelleme	Routing Subsystem	3.2, 3.6
FR6 — Uçtan Uca Şifreleme	Security Subsystem	3.2, 3.5
FR7 — Mesaj Durum Bildirimi	Application (UI) Subsystem	3.2, 3.6
FR8 — Yerel Veri Saklama	Local Message Store	3.4
FR9 — Hazır SOS Şablonları	Application (UI) Subsystem	3.2
NFR1 — İletim Gecikmesi ($p95 \leq 2$ sn)	Connectivity + Routing Subsystem	3.3, 3.6
NFR2 — Bellek Kullanımı (≤ 80 MB)	Tüm alt sistemler (kaynak bütçesi)	3.3
NFR3 — Batarya Tüketimi ($\leq \%2.5/\text{saat}$)	Connectivity Subsystem (keşif döngüsü)	1.2, 3.3
NFR4 — Ağ Teslimat Oranı ($\geq \%90$)	Routing + Connectivity Subsystem	3.1, 3.6
NFR5 — Şifreleme Standardı (X25519, PBKDF2)	Security Subsystem	3.5

4. Subsystem services

Bu bölüm, her alt sistemin diğer alt sistemlere sunduğu servisleri (arayüz düzeyinde işlevleri) listeler; kod seviyesinde bir API tanımı değil, tasarım düzeyinde bir sözleşmedir. Her servis için ön koşul (servisin çağrılabilmesi için gerekli durum) ve son koşul (servis başarıyla tamamlandığında garanti edilen durum) belirtilerek alt sistemler arası sözleşme netleştirilmiştir; bu, Detaylı Tasarım aşamasında doğrudan birim test senaryolarına dönüştürülebilecek bir temel sunar.

Application (UI) Subsystem — Servisler

Servis	Açıklama	Ön Koşul	Son Koşul
composeMessage(content, priority)	Kullanıcının yeni mesaj oluşturmasını sağlar (UC3)	Kullanıcı metin girdi	Security Subsystem'e

Servis	Açıklama	Ön Koşul	Son Koşul
			plaintext iletilir
triggerSOS(template)	Hazır SOS şablonlarından birini seçip acil gönderimi başlatır (UC1, FR9)	GPS izni verilmiş (opsiyonel)	SOS mesajı öncelikli olarak Security'ye iletilir
displayMessageStatus(messageId)	Mesajın güncel durumunu gösterir (FR7)	messageId Local Message Store'da mevcut	UI durum etiketini günceller
displayNetworkStatus()	Bağlı komşu sayısı, sinyal gücü, güç modu gösterir (UC7)	Connectivity Subsystem aktif	Güncel ağ görünümü ekrana yansır

Security Subsystem — Servisler

Servis	Açıklama	Ön Koşul	Son Koşul
generateKeyPair()	Cihaz için X25519 anahtar çifti üretir	İlk kurulum / cold start	Özel anahtar güvenli depoda saklanır
encryptPayload(plaintext, recipientPublicKey)	Payload'ı hedefin açık anahtarıyla şifreler (FR6)	Alıcı açık anahtarı biliniyor	Şifreli payload Routing'e geçer
decryptPayload(ciphertext)	Yalnızca hedef cihazda payload'ı çözer	Cihaz nihai alıcı	Düz metin UI'a iletilir
signHeader(header) / verifyHeaderSignature(header)	Paket başlığını HMAC ile imzalar/doğrular	Header alanları dolu	İmza doğrulanmış/reddedilmiş header

Routing Subsystem — Servisler

Servis	Açıklama	Ön Koşul	Son Koşul
routeMessage(packet)	Sıradaki komşuyu seçer, TTL'yi azaltır, öncelik kuyruğuna yerleştirir (FR2)	Paket şifrelenmiş ve imzalı	Paket Connectivity'ye devredilir veya Store'a yazılır

Servis	Açıklama	Ön Koşul	Son Koşul
isDuplicate(uuid)	Daha önce işlenmiş bir mesaj olup olmadığını kontrol eder (FR5)	UUID mevcut	true/false döner, gerekirse paket düşürülür
scheduleStoreAndForward(message)	Rota bulunamadığında mesajı Store'a devreder (FR4)	Menzilde uygun komşu yok	Mesaj status=PENDING olarak kaydedilir
onNeighborDiscovered(deviceId)	Yeni komşu keşfedildiğinde bekleyenleri yeniden dener	Yeni deviceId Connectivity'den bildirildi	Bekleyen mesajlar yeniden kuyruklanır

Connectivity Subsystem — Servisler

Servis	Açıklama	Ön Koşul	Son Koşul
startDiscovery() / stopDiscovery()	Periyodik BLE advertising/scanning döngüsünü yönetir (FR1)	Bluetooth izni verilmiş	Komşu listesi periyodik güncellenir
sendBytes(deviceId, payload)	Fiziksel katmanda veri gönderimi yapar	deviceId menzilde	Bayt dizisi karşı tarafa iletilir
onDataReceived(callback)	Gelen ham veriyi Routing Subsystem'e iletir	Aktif bağlantı mevcut	Routing'in isDuplicate/routeMessage'ı tetiklenir

Local Message Store — Servisler

Servis	Açıklama	Ön Koşul	Son Koşul
saveMessage(message) / getPendingMessages()	Mesajın kalıcı saklanması ve bekleyenlerin sorgulanması (FR8)	Room veritabanı erişilebilir	Mesaj diskte kalıcı hale gelir
markDelivered(messageId)	Mesaj durumunun güncellenmesi	messageId mevcut	status=DELIVERED olarak işaretlenir
purgeDeliveredOldest(limit)	Depolama doluluğunda en eski teslim edilmiş kayıtların temizlenmesi	Depolama sınırına yaklaşıldı	En eski DELIVERED kayıtlar silinir, PENDING/SOS korunur

Bu servis sözleşmeleri, Şekil 1'deki bileşen diyagramında gösterilen bağımlılık oklarıyla birebir örtüşür: UI yalnızca Security'yi, Security yalnızca UI ve Routing'i, Routing hem Security hem Connectivity hem de Local Message Store'u çağırabilir. Bu tek yönlü ve sınırlı bağımlılık kümesi, alt sistemler arasında dairesel bağımlılık (circular dependency) oluşmasını mimari düzeyde engeller.

5. Glossary

Terim	Tanım
Ad-Hoc Network	Önceden yapılandırılmış bir altyapıya ihtiyaç duymadan, cihazların anlık olarak birbirine bağlanmasıyla oluşan ağ.
Mesh Network	Her düğümün hem veri üreten hem de başkalarının verisini taşıyan olarak çalıştığı, merkezî bir noktaya bağımlı olmayan ağ yapısı.
Multi-hop	Bir mesajın kaynaktan hedefe, aradaki birden fazla cihaz üzerinden sıçrayarak ulaştırılması.
Flooding	Bir ağ düğümünün, kendisine gelen veriyi bağlı olduğu tüm diğer düğümlere koşulsuz kopyalayıp gönderdiği yönlendirme tekniği.
Relay	Kendisine ait olmayan bir mesajı alıp bir sonraki hedefe taşıyan aracı cihaz.
Payload	İletişim paketinin taşıdığı asıl yük/mesaj içeriği; projede uçtan uca şifrelidir.
TOFU (Trust-On-First-Use)	Merkezi doğrulama olmadan, bir cihazın açık anahtarının ilk karşılaşmada güvenilir kabul edilmesi ilkesi.
Cold start	Uygulamanın ilk kurulumdan sonra veya cihaz yeniden başlatıldıktan sonraki ilk çalıştırılma durumu.
Graceful Degradation	Sistemin, bileşen veya bağlantı kaybı durumunda tamamen çökmek yerine sınırlı işlevsellikle çalışmaya devam etmesi.
STRIDE	Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege — sistematik tehdit modelleme çerçevesi.
Traceability Matrix	Gereksinimlerin tasarım/mimari bileşenleriyle eşleştirildiği izlenebilirlik tablosu.
Shared Secret	İki tarafın Diffie-Hellman (X25519) anahtar değişimiyle bağımsızca türettiği, ağ üzerinden hiç taşınmayan ortak gizli değer.

6. References

- [1] Y. Murillo, B. Reynders, A. Chiumento, S. Malik, P. Crombez, and S. Pollin, "Bluetooth now or low energy: Should BLE mesh become a flooding or connection oriented network?" in Proc. IEEE PIMRC, Montreal, QC, Canada, Oct. 2017, pp. 1–6, doi: 10.1109/PIMRC.2017.8292705.
- [2] M. R. Ghorri, T.-C. Wan, and G. C. Sodhy, "Bluetooth Low Energy mesh networks: Survey of communication and security protocols," Sensors, vol. 20, no. 12, Art. no. 3590, Jun. 2020, doi: 10.3390/s20123590.

- [3] A. A. Pirzada, M. Portmann, R. Wishart, and J. Indulska, "SafeMesh: A wireless mesh network routing protocol for incident area communications," *Pervasive and Mobile Computing*, vol. 5, no. 2, pp. 201–221, Apr. 2009, doi: 10.1016/j.pmcj.2008.11.005.
- [4] M. R. Albrecht, R. Eikenberg, and K. G. Paterson, "Breaking Bridgefy, again: Adopting libsignal is not enough," in *Proc. 31st USENIX Security Symp.*, Boston, MA, USA, Aug. 2022, pp. 269–286.
- [5] C. E. Perkins, E. M. Belding-Royer, and S. Das, "Ad hoc on-demand distance vector (AODV) routing," IETF, RFC 3561, Jul. 2003. [Online]. Available: <https://datatracker.ietf.org/doc/rfc3561/>
- [6] D. Cooper, S. Santesson, S. Farrell, S. Boeyen, R. Housley, and W. Polk, "Internet X.509 public key infrastructure certificate and certificate revocation list (CRL) profile," IETF, RFC 5280, May 2008. [Online]. Available: <https://www.rfc-editor.org/info/rfc5280>
- [7] A. Langley, M. Hamburg, and S. Turner, "Elliptic curves for security," IETF, RFC 7748, Jan. 2016. [Online]. Available: <https://www.rfc-editor.org/info/rfc7748>
- [8] IEEE Standard for Telecommunications and Information Exchange Between Systems — LAN/MAN — Specific Requirements — Part 15.1: Wireless Medium Access Control (MAC) and Physical Layer (PHY) Specifications for Wireless Personal Area Networks (WPANs), IEEE Std 802.15.1, 2005.
- [9] A. Lacava, V. Zottola, A. Bonaldo, F. Cuomo, and S. Basagni, "Securing Bluetooth Low Energy networking: An overview of security procedures and threats," *Computer Networks*, vol. 211, Art. no. 108953, Jul. 2022, doi: 10.1016/j.comnet.2022.108953.
- [10] J. Höglund, S. Lindemer, M. Furuheid, and S. Raza, "PKI4IoT: Towards public key infrastructure for the Internet of Things," *Computers & Security*, vol. 89, Art. no. 101658, Feb. 2020, doi: 10.1016/j.cose.2019.101658.